Unauthenticated Database Backup Disclosure

1. Report Title: Full Database Dump Publicly Downloadable (`elmsdb.sql`)

2. Finding ID: ELMS-003

3. Vulnerability Name: Sensitive data exposure — SQL backup served from the web root

4. Executive Summary

The application's SQL dump is shipped inside the web root and served to anyone with HTTP 200. It contains the full schema plus all seeded data: every employee's PII and **all password hashes, including the administrator's** . Because the hashes are unsalted MD5 (ELMS-004), they crack instantly, giving an unauthenticated attacker working credentials for every account and the admin panel.

5. Severity

High

6. CVSS 4.0

`CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N` ? Base **?8.7 (High)** . Direct high-confidentiality exposure to an anonymous attacker; integrity/availability indirect (via cracked credentials ? ELMS-004 chain).

7. OWASP Classification

A05:2021 – Security Misconfiguration (also A01 Broken Access Control; A02 via disclosed hashes).

8. CWE Classification

CWE-538 (File/Directory Information Exposure); CWE-540 (Information Exposure Through Source/Config); CWE-522 (Insufficiently Protected Credentials); CWE-200.

9. Affected URL

`http://localhost/elms/elmsdb.sql` and `http://localhost/elms/SQL%20File/elmsdb.sql`

10. Affected Parameter

None (static file retrieval).

11. Authentication Requirements

None.

12. Affected User Roles

All (data of every employee and the admin is exposed); attacker is anonymous.

13. Vulnerability Description

`elmsdb.sql` (and a duplicate under `SQL File/`) resides in the deployed web root and is returned as static content. The dump includes `CREATE TABLE` definitions and `INSERT` rows for `admin` , `tblemployees` , `tbldepartments` , `tblleaves` , `tblleavetype` — i.e., credentials and PII.

14. Technical Root Cause

Deployment hygiene failure: a database backup / installer artifact left web-accessible, with no web-server rule denying `.sql` (and directory listing enabled, ELMS-009, makes discovery easier).

15. Preconditions

None. The filename is predictable (ships with the product) and also discoverable via the enabled directory listing.

16. Proof of Concept

`GET /elms/elmsdb.sql` returns HTTP 200 with the dump; the admin row is present:

`(1, 'admin', '5c428d8875d2948607f3e3fe134d71b4', ...)` . That MD5 equals `Test@12345` (confirmed, see ELMS-004), and all three employee rows share `f925916e2754e5e03f75dd58a5733251` = `Test@123` .

17. Reproduction Steps

1. Without authenticating, request `GET /elms/elmsdb.sql` .
2. Observe HTTP 200 and the full SQL dump in the body.
3. Note the `admin` INSERT with hash `5c428d8875d2948607f3e3fe134d71b4` and the `tblemployees` rows with emails + hashes.
4. Crack the MD5 (dictionary/rainbow) ? plaintext passwords; log in to `/admin/` and `/index.php` .

18. HTTP Request Evidence

```
GET /elms/elmsdb.sql HTTP/1.1
Host: localhost
(no authentication)
```

Evidence: `.../evidence/07_elmsdb_sql.resp` .

19. HTTP Response Evidence

```
HTTP/1.1 200 OK
...
INSERT INTO `admin` (`id`, `UserName`, `Password`, ...) VALUES
(1, 'admin', '5c428d8875d2948607f3e3fe134d71b4', '2023-08-31 11:42:58');
INSERT INTO `tblemployees` ... VALUES
(1,'10805121','Rahul','Kumar','rk1995@test.com','f925916e2754e5e03f75dd58a5733251', ...)
```

(Hashes shown as disclosed by the target; they are lab data.)

20. Screenshots

Not captured (headless env; Playwright unavailable — blocked, not fabricated).

21. Security Impact

Anonymous full disclosure of the database: all employee PII and all credential hashes. Via ELMS-004 the admin and every employee password is recovered ? complete application compromise (confidentiality, integrity and availability of all data).

22. Exploitation Feasibility

Immediate for disclosure; credential recovery is seconds against unsalted MD5. No authentication or special tooling.

23. Existing CVE Verification

No CVE — this is a deployment/configuration exposure specific to how the instance was installed (backup left in web root), not a code CVE. Status: **No matching CVE identified / not applicable** .

24. References

- OWASP WSTG-CONF-04 (Old/Backup & Unreferenced Files); A05:2021; CWE-538/540/522.

25. Remediation

Remove `elmsdb.sql` , the `SQL File/` directory, and `readme.txt` from the web root. Keep backups outside the document root. Add a web-server rule denying sensitive extensions, e.g. Apache:

```
<FilesMatch "\.(sql|bak|old|inc|sql\.gz|zip)$">
  Require all denied
</FilesMatch>
```

Disable directory listing (ELMS-009). Rotate all credentials that were ever exposed.

26. Recommended Secure Code Example

Not a code defect; remediation is deployment + web-server configuration (see §25). Additionally store passwords with `password_hash()` (ELMS-004) so that any future dump exposure does not yield trivially crackable hashes.

27. Retest Procedure

Request `/elms/elmsdb.sql` and `/elms/SQL%20File/elmsdb.sql` unauthenticated. Fixed behaviour: HTTP 403/404 for both, and the files are absent from the web root.

28. Final Conclusion

Confirmed unauthenticated disclosure of the complete database including admin and employee credentials. High severity and the root of the "download ? crack ? log in" compromise chain. Remove the artifacts and block sensitive file types.